Министерство науки и высшего образования Российской Федерации
Федеральное государственное автономное образовательное учреждение
высшего образования
«Московский государственный технический университет имени Н.Э. Баумана
(национальный исследовательский университет)»
(МГТУ им. Н.Э. Баумана)

ФАКУЛЬТЕТ **ИНФОРМАТИКА И СИСТЕМЫ УПРАВЛЕНИЯ**

КАФЕДРА **КОМПЬЮТЕРНЫЕ СИСТЕМЫ И СЕТИ (ИУ6)**

НАПРАВЛЕНИЕ ПОДГОТОВКИ **09.03.01/03 Вычислительные машины, комплексы, системы и сети**

Д О М А Ш Н Е Е З А Д А Н И Е

Название: Сервис аренды повербанков

Дисциплина: Защита информации

Студент	ИУ6-83Б		В.К. Зальгин
	(Группа)	(Подпись, дата)	(И.О. Фамилия)
Преподаватель			Д.А. Миков
		(Подпись, дата)	(И.О. Фамилия)

Москва, 2026

ВВЕДЕНИЕ

В условиях активного развития цифровых сервисов и городской мобильной инфраструктуры всё большее распространение получают автоматизированные системы краткосрочной аренды устройств. Одним из таких решений является сервис аренды повербанков, позволяющий пользователю временно получить переносной источник питания через публичную станцию самообслуживания с последующим возвратом в любую совместимую точку сети.

Подобный сервис представляет собой не просто совокупность физических устройств, а полноценную автоматизированную информационную систему, включающую пользовательские мобильные приложения, веб-интерфейсы, серверную часть, базы данных, платёжные модули, телеметрию станций и средства администрирования. В связи с этим в системе обрабатывается значительный объём данных различной категории: персональные данные пользователей, сведения о платежах, служебная и технологическая информация, журналы операций, конфигурации оборудования и другие данные, имеющие ценность для организации и потенциальный интерес для нарушителя.

Актуальность рассмотрения вопросов защиты информации в сервисе аренды повербанков обусловлена тем, что данная система функционирует в условиях открытой среды, сочетая сетевое взаимодействие, удалённое управление, физически доступные устройства и финансовые операции. Это делает её потенциальной целью как для внешних злоумышленников, так и для внутренних нарушителей, а также создаёт предпосылки для случайных сбоев, ошибок конфигурации и нарушений порядка обработки информации.

Целью данной работы является анализ типового сервиса аренды повербанков как объекта защиты информации, выявление рисков нарушения конфиденциальности, целостности и доступности информации, исследование информационных процессов внутри системы, а также разработка предложений по политике безопасности, средствам и методам защиты.

Для достижения поставленной цели решаются следующие задачи:

– определить состав информационных активов сервиса аренды повербанков;

– выделить основные информационные процессы и потоки данных;

– установить возможные источники и виды угроз;

– оценить риски нарушения конфиденциальности, целостности и доступности информации;

– предложить направления, способы, средства и методы защиты информации;

– сформулировать положения политики безопасности для рассматриваемой автоматизированной системы.

Объектом исследования является автоматизированная система сервиса аренды повербанков. Предмет исследования — угрозы информационной безопасности, риски нарушения свойств информации и организационно-технические меры защиты, применимые к данной системе.

1 Выполнение задания

Типичный клиентский сценарий в сервисе аренды повербанков выглядит следующим образом: пользователь приходит к станции, запускает аренду с экрана станции или в приложении, оплачивает услугу банковской картой или устройством и получает повербанк. Возврат выполняется вставкой повербанка в свободный слот любой станции сети и подтверждается системой.

В практиках операторов встречаются механизмы обеспечения возврата, например депозит или холд средств. Это напрямую влияет на модель рисков, в частности на мошенничество, невозвраты и спорные транзакции, а также на требования к журналированию и разбору инцидентов.

С архитектурной точки зрения сеть станций представляет собой распределённую систему вида «устройства + backend + клиентские приложения». Станция в публичном месте функционально близка к IoT-устройству: она хранит состояние, выполняет команды, обменивается телеметрией и событиями с серверной частью, а также взаимодействует с платёжной инфраструктурой.

В сервисе аренды повербанков ключевые активы — это не только персональные данные пользователей, но и машинные данные: состояние станций, прошивки, ключи, журналы, а также данные, связанные с платежами и противодействием мошенничеству.

К основным информационным активам относятся персональные данные пользователей, включая учётную запись, контактные данные, историю аренд, время и точки аренды и возврата, а иногда и геолокацию. Также к ним относятся платёжные данные: токены платежей, статусы транзакций, сведения о холдах и депозитах, данные для разбора спорных списаний. Важную роль играют и технические активы оператора: прошивки станций, конфигурации, приватные ключи устройств и серверов, секреты API, административные учётные записи, журналы безопасности.

Если рассматривать источники информации в данной системе, то к ним относятся пользователь, станция, backend, платёжный провайдер или банк,

персонал эксплуатации и партнёрские точки размещения. Каждый из этих источников формирует или передаёт данные, которые должны быть защищены.

Основные информационные процессы в сервисе аренды повербанков включают аренду, возврат, эксплуатацию и обслуживание, а также обновление программного обеспечения станций. При аренде пользователь инициирует операцию на станции или в приложении, система проверяет право на аренду, лимиты и подтверждение платежа, после чего отправляет станции команду выдать повербанк. Станция фиксирует событие выдачи и отправляет подтверждение с указанием идентификатора слота, идентификатора повербанка и времени.

При возврате станция принимает повербанк, проверяет его идентификатор и совместимость, фиксирует событие возврата, а backend закрывает аренду и инициирует окончательное списание либо разблокировку депозита в соответствии с правилами тарификации.

В процессе эксплуатации и обслуживания персонал выполняет перераспределение повербанков, замену неисправных устройств, проверку оборудования и иные технические действия. Для этого необходимы доверенные административные каналы и надёжное журналирование действий сотрудников.

Удалённые обновления программного обеспечения станций также являются важным информационным процессом. Они должны быть защищены криптографически и организационно: требуется проверка источника обновления, контроль целостности, безопасная доставка и защита сервера обновлений.

Коммуникации между приложением, станцией и backend должны обеспечивать конфиденциальность и целостность передаваемой информации.

При анализе угроз для сервиса аренды повербанков следует учитывать, что он включает мобильное приложение, API, backend, административную панель, платёжную инфраструктуру и физически доступные устройства. Это делает систему уязвимой сразу в нескольких плоскостях.

К источникам угроз относятся внешние атакующие из сети Интернет, злоумышленники, имеющие физический доступ к станции, недобросовестные пользователи, инсайдеры, подрядчики, а также ошибки конфигурации и эксплуатации. Кроме того, существует риск компрометации цепочки поставки программного и аппаратного обеспечения.

Основными видами угроз являются компрометация аутентификации и пользовательских сессий, недостатки авторизации в API, раскрытие данных, подмена и искажение событий аренды и возврата, отказ в обслуживании, компрометация прошивки и механизма обновлений, а также физическое вмешательство в станцию.

Объектами угрозы выступают backend API и база данных, платёжный контур, мобильное приложение, административная панель, устройства станций, инфраструктура обновлений, секреты и ключи, а также журналы и средства мониторинга.

Способы доступа к системе со стороны нарушителя могут быть удалёнными, через API и веб-интерфейсы, через мобильное приложение, физическими — при доступе к корпусу станции, портам и debug-интерфейсам, а также через механизм обновлений и цепочку поставки.

Оценку рисков удобно представлять в виде реестра (таблица 1) указанием нарушаемых свойств информации, источника угроз и основных защитных мер.

В графе «Что нарушается» используется классификация по базовым свойствам информации: конфиденциальности, целостности и доступности. Для краткости в таблице применяются обозначения C, I и A, где C означает конфиденциальность, I — целостность, а A — доступность. Такая классификация позволяет показать, какое именно свойство информации или системы нарушается в результате реализации конкретной угрозы.

В графе «Уровень» используется качественная шкала оценки риска. Обозначение H соответствует низкому уровню риска, C — среднему, B — высокому, а C–B — промежуточной оценке между средним и высоким уровнями. Данная оценка носит экспертный характер и определяется с

учётом вероятности реализации угрозы и тяжести возможных последствий для рассматриваемой системы.

Таблица 1 — Описание сценариев риска

Сценарий риска	**Что нарушается**	**Типичный источник угроз**	**Уровень**	**Ключевые меры**
Захват аккаунта пользователя и просмотр или изменение истории аренд и привязок	C/I	Внешний атакующий, фишинг, утечка паролей	B	Надёжная аутентификация, защита сессии, ограничение попыток входа
Ошибки авторизации в API, дающие доступ к чужим арендам и платежам	C/I	Внешний атакующий	B	Корректное проектирование авторизации и тестирование API
Утечка персональных данных из базы данных, журналов или аналитики	C	Внешний атакующий, инсайдер, ошибка настройки	B	Минимизация данных, контроль доступа, шифрование, защита журналов
Компрометация административной панели	C/I/A	Внешний атакующий, инсайдер	B	Многофакторная аутентификация, сегментация доступа, безопасная разработка
Подмена событий «выдача» и «возврат»	I	Недобросовестный пользователь, атака на станцию или канал связи	C–B	Неподделываемые журналы, привязка транзакции к устройству и слоту, аутентичность сообщений
Вмешательство в станцию, вскрытие корпуса и извлечение секретов	C/I/A	Физический злоумышленник	B	Tamper-защита, шифрование хранилища, ограничение портов, защита debug-интерфейсов
Использование универсальных паролей и секретов на станциях	C/I/A	Массовые атаки, ботнет-сценарии	B	Уникальные секреты на каждое устройство, отказ от паролей по умолчанию

Продолжение таблицы 1

Сценарий риска	**Что нарушается**	**Типичный источник угроз**	**Уровень**	**Ключевые меры**
Компрометация канала обновлений и внедрение вредоносной прошивки	C/I/A	Компрометация цепочки поставки, взлом сервера обновлений	B	Подписанные обновления, проверка цепочки доверия, защищённая доставка OTA
DDoS на API или backend	A	Внешний атакующий	C–B	Резервирование, устойчивость, ограничение частоты запросов
Инцидент с персональными данными и нарушение сроков уведомления	C/ комплаенс	Ошибка процесса реагирования	C	Подготовленные процедуры реагирования на инциденты и уведомления

Отдельно следует отметить, что сервис аренды повербанков практически неизбежно обрабатывает временные и локационные данные, в частности сведения о том, где была выполнена аренда и возврат.

Политику безопасности для рассматриваемой системы целесообразно строить как совокупность обязательных организационных, технических и физических мер.

К организационным мерам относятся управление рисками, распределение ролей и допусков, управление изменениями и поставщиками, обучение персонала и регламенты реагирования на инциденты.

К техническим мерам относятся управление идентификацией, аутентификацией и авторизацией, криптографическая защита данных при хранении и передаче, безопасность приложений и API, мониторинг и журналирование, безопасные обновления и сегментация сети.

К физическим мерам относятся защита станций в публичной среде, применение пломб и датчиков вскрытия, ограничение доступа к портам, защита debug-интерфейсов, а также безопасная замена и утилизация накопителей.

В качестве основных способов защиты следует использовать регулярную оценку рисков, моделирование угроз, безопасную разработку серверной части, мобильного приложения и прошивок станций, а также готовность к реагированию на инциденты и обработке утечек персональных данных.

Практические средства защиты должны включать надёжную аутентификацию и безопасное управление сессиями, обязательную многофакторную аутентификацию для администраторов и технического персонала, корректную защиту API и веб-панелей, использование криптографической защиты транспортных каналов, централизованное логирование и мониторинг, а также меры защиты станций как IoT-устройств.

Для станций особенно важно исключить использование универсальных паролей по умолчанию, применять уникальные секреты для каждого устройства, защищать или отключать debug-интерфейсы, минимизировать число внешних портов, безопасно хранить ключи и секреты, а также защищать механизм OTA-обновлений.

Отдельное внимание должно уделяться платёжной безопасности, включая минимизацию объёма обрабатываемых платёжных данных, вынесение критичных данных в специализированный платёжный контур и защиту операций списания, холда и возврата.

Не менее важны требования к приватности: минимизация объёма собираемых данных, установление сроков хранения, разграничение доступа, процедуры удаления или обезличивания данных, а также регламент действий при утечках.

ЗАКЛЮЧЕНИЕ

Сервис аренды повербанков представляет собой распределённую автоматизированную информационную систему, в которой сочетаются мобильные и веб-компоненты, backend, платёжная инфраструктура и публично доступные устройства. Это создаёт широкий спектр рисков, затрагивающих конфиденциальность, целостность и доступность информации.

Наиболее значимыми для такого сервиса являются риски компрометации учётных записей, ошибок авторизации, утечек персональных данных, подмены событий аренды и возврата, физического вмешательства в станции, а также атак на механизм обновлений и на доступность backend.

Для снижения этих рисков требуется сочетание организационных, технических и физических мер защиты. Политика безопасности должна охватывать весь жизненный цикл системы: от проектирования и разработки до эксплуатации, обновления и реагирования на инциденты.